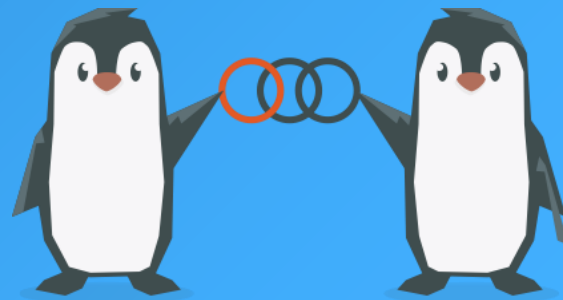


OpenChain SBOM WG

SBOM Document Quality Guide

CNCJ: Software Supply Chain & Application Security Meetup

2026-05-26



Who am I



Norio Kobota / norio.kobota@sony.com

Senior Open Source Strategist, Sony Group Corporation

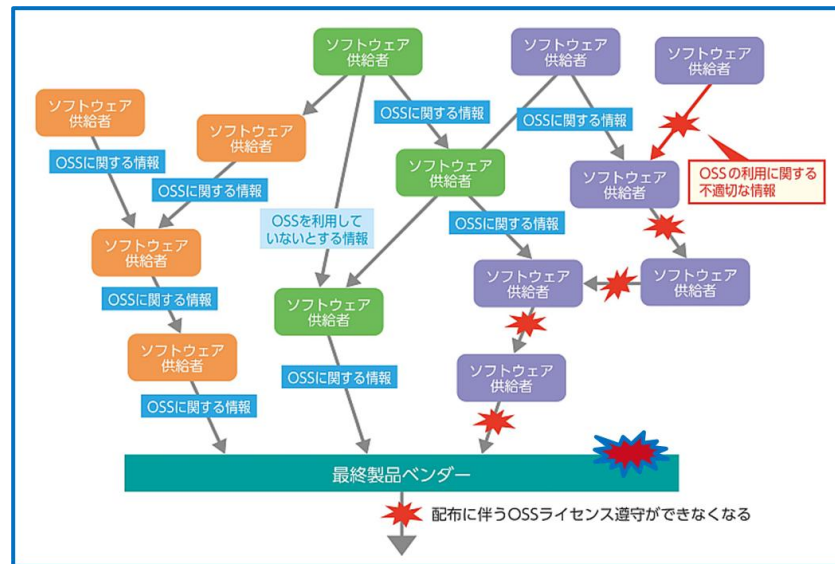
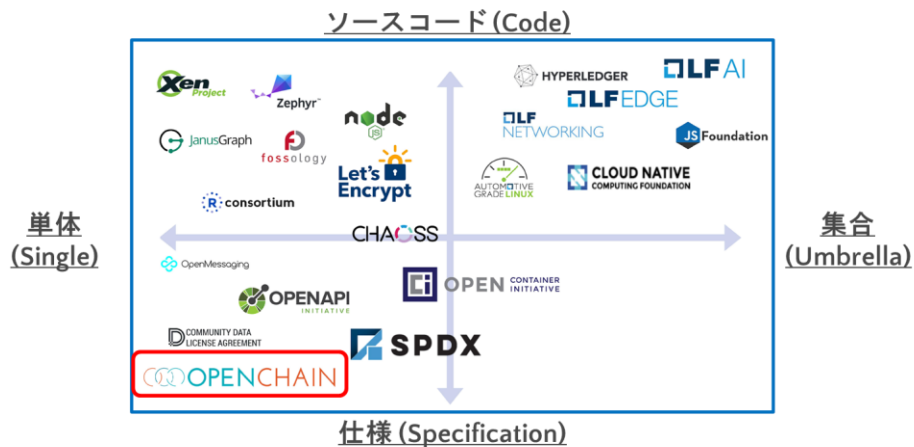
Leading Sony Group internal Open Source Software License Committee and works to improve OSS compliance and relationships with OSS communities.

He represents Sony as a board member of OpenChain Project and leading SBOM working group since 2024. And he is participating the SPDX Project and contributing the SPDX Lite profile.

OpenChain Project とは?

オープンソースが、一貫したプロセスで管理され、信頼できる情報が提供されるサプライチェーンを実現する為の活動を行う Linux Foundation プロジェクトの1つ。

Linux Foundation内での位置付け



複雑なソフトウェアサプライチェーン
の元、ライセンスコンプライアンスの
課題を解決する目的で活動

OpenChain Project の3つの柱

1. 仕様 (Specification)

- 企業が組織内に確立すべきコンプライアンスプログラム（仕組み・体制等）の要件を定義
- ISO/IEC 5230:2020 (License Compliance), ISO/IEC 18974:2023 (Security Assurance) として国際標準化

2. 適合 (Conformant)

- 自己認証と第三者認証。仕様に関するアンケートに回答して適合を宣言することが可能

3. カリキュラム (Curriculum)

- 仕様に適合させるための、各組織で利用可能な教育資料集の提供



OpenChain Projectの活動体制

Governing Board は、プラチナ メンバーで構成

- Linux Foundation のメンバーシップ
- OpenChain Project のメンバーシップ
- Board Chair は、ボードメンバーから選出
現在はEricssonのJimmy Ahlberg さん
- General Managerは、Linux Foundation の Shane Coughlan さん → Mary Wang さん(2026.03-)



We Are Supported By Our Platinum Members:



TOYOTA

現在ボード企業は25社

Working Group は、コミュニティメンバーで構成

- ML、電話会議、ワークショップ等、誰でも参加可能
- 各Leaderは、コミュニティメンバーから選出

Global Work Groups

- AI Dave Marr, Qualcomm
Matthew Crawford, Arm
- Automotive Masato Endo, Toyota
- Education Martin Yagi, First Light Fusion
- **SBOM** **Norio Kobota, Sony**
- Specification Chris Wood, Lockheed Martin
Oliver Fendt, Siemens
- Tooling Marc-Etienne Vargenau, Nokia
- Telco

Regional Work Groups

- China Zhenhua Sun, ByteDance
- Germany *No Chair*
- Japan Ayumi Watanabe, Hitachi Solutions
- Korea Haksung Jang, SK Telecom
- India Buji K. Nair
- Taiwan *No Chair*

SPDX LITE (~v2.3) / LITE PROFILE (v3.0~)

<https://spdx.dev/learn/areas-of-interest/lite/>



Definition

The Light profile captures the minimum set of information required for license compliance in the software supply chain. This profile contains information about the creation of the SBOM, package lists with licensing and other related items, and their relationships.

This profile was implemented with the contribution of the OpenChain Japan working group.

Essentially, this profile defines the minimum items required to **comply with open source license compliance**. But designed to **meet the requirements of regulations and guidelines around the world**.



H.2 Table of the Lite profile elements

A SPDX document with the Lite profile must include properties for each class listed in **Table H.1**. And **Cardinality 1..1** means a **REQUIRED** element, and the others **SHOULD** be filled in as much as possible if necessary.

Table H.1 — the Lite profile elements

1. For a /Core/SpdxDocument to be conformant with this profile, the following has to hold:

#	Property Name	Cardinality	Comments
1	/Core/SpdxDocument/spdxId	1..1	
2	/Core/SpdxDocument/name	0..1	
3	/Core/SpdxDocument/comment	0..1	
4	/Core/SpdxDocument/creationInfo	1..1	
5	/Core/SpdxDocument/verifiedUsing	0..1	This should be an object of /Core/Hash
6	/Core/SpdxDocument/element	1..*	MUST have at least one element
7	/Core/SpdxDocument/rootElement	1..1	This should be an object of /Core/Sbom
8	/Core/SpdxDocument/namespaceMap	0..*	
9	/Core/SpdxDocument/dataLicense	0..1	

1. For a /Core/NameSpaceMap to be conformant with this profile, the following has to hold:

#	Property Name	Cardinality	Comments
---	---------------	-------------	----------

<https://spdx.github.io/spdx-spec/v3.0/annexes/SPDX-Lite/>



 In the Public Comment Period!

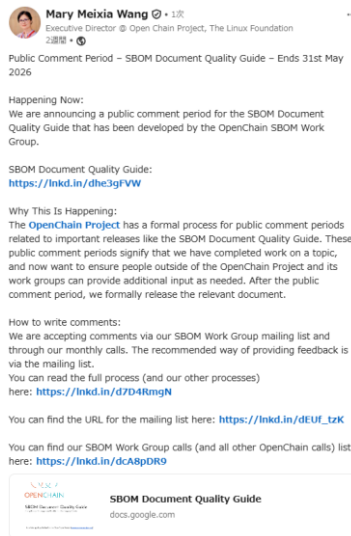
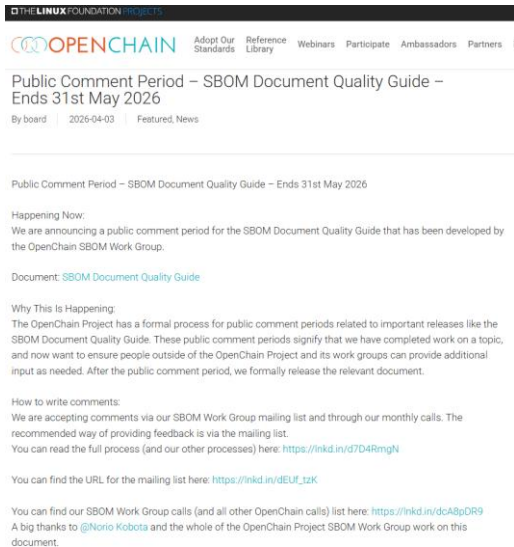


SBOM Document Quality Guide

Compliance Management Guide for the Supply Chain

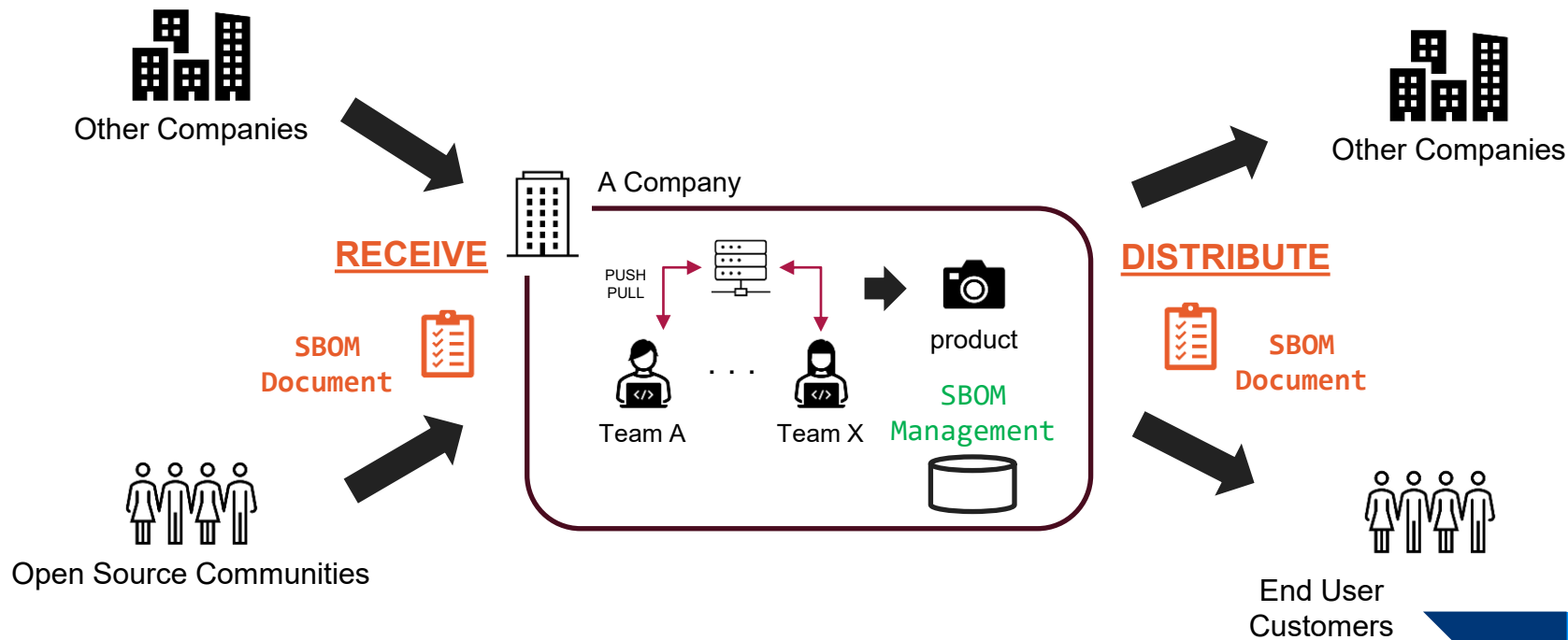
An official guide published by the OpenChain Project (www.openchainproject.org)

Version: 2026.04.03



<https://openchainproject.org/news/2026/04/03/public-comment-period-sbom-document-quality-guide-ends-31st-may-2026>

Scope and Definition



Guideline to Enhance SBOM Document Quality

3.2 SBOM Elements

An SBOM Document SHALL include all the SBOM Elements defined in this chapter, which the OpenChain SBOM Document Quality Guide considers indicative of high quality.

SBOM Document Information

- Data Format Version
- License for the SBOM Document
- Unique ID for the SBOM Document
Include a global unique identifier in the SBOM Document. The specification for this unique ID is in the Data Format;
For example, CycloneDX has 'serialNumber', must be global unique or a combination of 'Data Format' and 'Version' used to ensure uniqueness.

Package information

- **Information that can uniquely identify a software package**
For accurate license compliance and vulnerability assessment, it is essential to correctly identify each software package. The document should include the following elements to ensure proper identification:
 - Package Name
 - Package Version
 - Details regarding the package identifiers, such as the [SoftWare Hash Identifiers \(SWHID\)](#), the [package URL \(PURL\)](#), [CPE](#) or the URL of the package distribution site, indicating where the corresponding software package can be obtained.

Rather than emphasizing the literal values of names or versions, **it is crucial to provide information that uniquely identifies the software packages** in use or distribution.

Common SBOM Document Quality Issues and Improvement Measures

5.6 Clarifying the Scope of Descriptions and Defining Accountability

5.6.1 Issue Overview

SBOM documents largely rely on the provider's discretion, resulting in inconsistent comprehensiveness and accuracy of the required information. Consequently, essential data may be missing across the software supply chain, increasing the risk of confusion in managing security and license compliance.

5.6.2 Detailed Description

Various guidelines and specifications exist, yet the criteria for including dependent components in an SBOM and the level of detail required for each component remain unclear.

- Only a limited set of necessary details, such as the scope of software dependencies and version information, may be included.
- It is often unclear who is accountable for each component, as contact information and management responsibilities are not clearly defined. This lack of clarity hampers rapid response when issues arise.

Consequently, incomplete information within the SBOM can prevent a full understanding of vulnerabilities and license-related risks across the entire software supply chain, potentially impeding effective security measures.

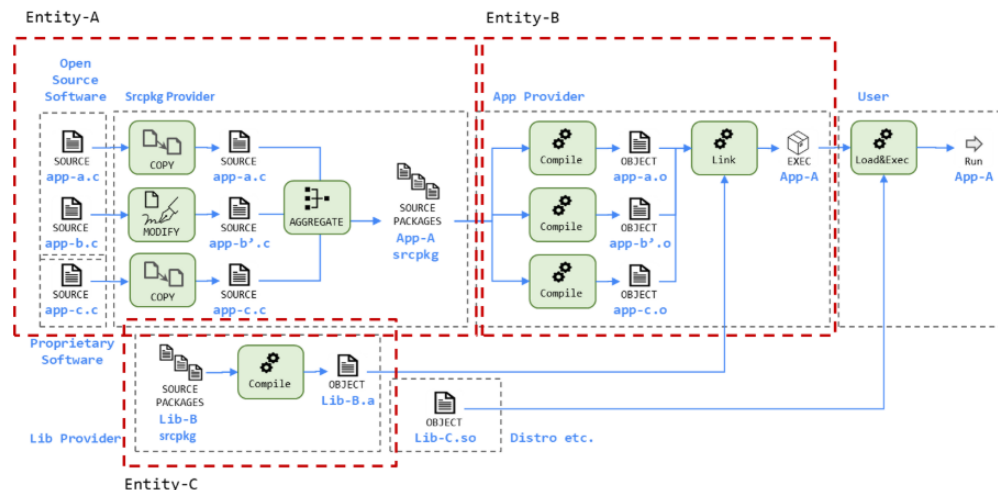


Fig.5-7.2 Three entities for "App-A SBOM Document" provided to "User".

"Entity-B" is generally responsible for direct vulnerability response and OSS license compliance for "User". There is no requirement to provide "User" with the contact details of "Entity-A" and "Entity-C"; however, "Entity-B" must know the proper contact information for "Entity-A" and "Entity-C". Consequently, the SBOM Document provided by "Entity-A" and "Entity-C" must include their respective appropriate contact details.

Compliance Elements in Relation to Legislation and Guidelines

6.1 NTIA - The Minimum Elements For a Software Bill of Materials (SBOM)

<https://www.ntia.gov/report/2021/minimum-elements-software-bill-materials-sbom>

6.1.1 Required Elements

Requirement Level	Element Name	SPDX v2.2+	SPDX v3.0	CycloneDX v1.6
SHALL	Supplier Name	(7.5) Package Supplier	Core/Classes/Artifact.supplierBy	bom.metadata.supplier, bom.components[].supplier
SHALL	Component Name	(7.1) Package Name	Software/Classes/Package.name inherited from Core/Classes/Element.name	bom.components[].name
SHALL	Version of the Component	(7.3) Package Version	Software/Classes/Package.packageVersion	bom.components[].version

6.3 BSI TR-03183 Cyber Resilience Requirements for Manufacturers and Products Part 2: Software Bill of Materials (SBOM) Version 2.1.0

https://www.bsi.bund.de/EN/Themen/Unternehmen-und-Organisationen/Standards-und-Zertifizierung/Technische-Richtlinien/TR-nach-Thema-sortiert/tr03183/TR-03183_node.html

6.3.1 Required Elements

TR-03182 version 2.1.0 does not allow SPDX v2.

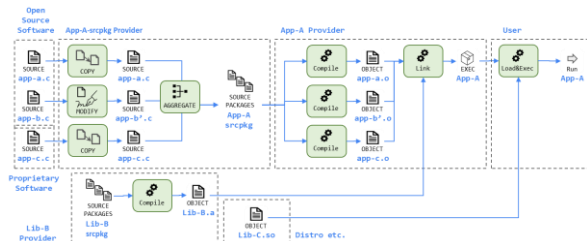
Requirement Level	Element Name	SPDX v2.2+	SPDX v3.0	CycloneDX v1.6
SHALL	Creator of the SBOM	N/A	Core/Classes/CreationInfo.createdBy	bom.metadata.manufacturer[].url XOR bom.metadata.manufacturer[].contact[].email
SHALL	Timestamp	N/A	Core/Classes/CreationInfo.created	bom.metadata.timestamp
SHALL	Component creator	N/A	Software/Classes/Package.OriginatedBy	bom.components[].manufacturer[].url XOR bom.components[].manufacturer[].contact[].email

6.4 OpenChain Telco SBOM Guide Version 1.1

<https://github.com/OpenChain-Project/Telco-WG/blob/main/OpenChain-Telco-SBOM-Guide-EN.md>

6.4.1 Required Elements

Requirement Level	Element Name	SPDX v2.2+	SPDX v3.0	CycloneDX v1.6
	Document Creation Information			
SHALL	SPDXVersion: mandatory in SPDX	(6.1) SPDX Version	(Core/CreationInfo.specVersion)	(specVersion)
SHALL	DataLicense: mandatory in SPDX	(6.2) Data License	(Core/SpdxDocument.dataLicense)	(metadata.license)
SHALL	SPDXID: mandatory in SPDX	(6.3) SPDX Identifier	(Core/SpdxDocument.spdxid)	(serialNumber)



Cover the required elements for various guidelines and will provide specific SBOM Document in JSON files for a particular use case in the future.

We already have many public comments.

No	From	Comments Abstract	The relevant text	Relevant Clauses	Our Response
1	Ibrahim Haddad	CRA requires retention for ten years or the product support period, whichever is longer, but this is not addressed in the guide.	The retention obligations are not addressed. The CRA mandates ten years or the product support period, whichever is longer.	Main: 6.1, Sub: Add to Chapter 3	This guide discusses quality considerations for handling general SBOM documents, so it does not address CRA-specific retention periods and does not need to include them as requirements in Chapter 3.
2	Ibrahim Haddad	The relationship between reporting deadlines (e.g., 24h/72h) and SBOM quality requirements should be clarified.	The CRA's vulnerability reporting timelines (24h, 72h, 14 days, one month) should be connected to SBOM quality requirements, as the SBOM is the instrument that enables compliance with those timelines.	Main: 6.1, Sub: Add to Chapter 3	This guide does not claim that meeting the Quality Guide requirements means full compliance with the CRA. It only defines requirements related to the quality of the documented content, not regulatory compliance.
3	Ibrahim Haddad	The text uses "SHALL" wording in CISA 2025 guidance, but it is unclear whether this is a draft or a final version.	The CISA 2025 guidance is presented with mandatory SHALL language without disclosing whether it has been finalized or remains a draft.	6.3	At this stage, CISA 2025 is still in draft form, and this should be clearly noted. We will update this guide once the reference is formally published.
4	Ibrahim Haddad	Traceability obligations for critical infrastructure operators are not reflected.	China's Cybersecurity Law and associated regulations impose SBOM-aligned traceability obligations on critical infrastructure operators and are not addressed in the guide.	6.0	
5	Ibrahim Haddad	It should be stated that the rule applies only to U.S. federal procurement and has no direct force on the private sector.	The scope of the US EO 14028 should be clarified; it is limited to US federal procurement and carries no direct enforcement mechanism for the broader private sector.	6.2	
6	Ibrahim Haddad	Validation, update frequency, distribution control, and retention are not described.	The guide covers SBOM document quality at the moment of exchange but does not address lifecycle management: verification, update cadence, sign-off, distribution controls, and retention. These are critical phases in the lifecycle of the SBOM covered in my report	Add to Chapter 3	
7	Ibrahim Haddad	Section 3.4 covers only the initial delivery.	The obligation to generate a new SBOM with every software update is not mentioned. Section 3.4 covers initial delivery timing only.	3.4	
8	Ibrahim Haddad	Guidance is needed on which department owns the SBOM process.	Organizational accountability is treated only as a document field problem. I believe the guide should address or provide guidance on which function owns the SBOM process, not just which fields to populate.	Add to Chapter 3	
9	Ibrahim Haddad	Configuration data that includes vulnerability information should be access-controlled.	The confidentiality guidance in section 3.7 prohibits redistribution restrictions, which conflict with the security practice of controlling access to component inventories that reveal unpatched vulnerabilities. (I've covered this topic in my report)	3.7	
10	Ibrahim Haddad	Build integration and binary analysis should also be included.	Verification methods in section 3.6 are limited to digital signatures. However, other methods exist, such as Build system integration, hash comparison, and binary analysis, which are established techniques that should be mentioned or included.	3.6	
11	Ibrahim Haddad	It is unclear where to start.	The guide does not offer a phased adoption path or prioritization guidance. Organizations at different maturity levels have no way to identify where to start. I believe there will be high value in providing guidance on the adoption path.	Add to Chapter 2	
12	Ibrahim Haddad	Transitive dependency coverage should be a SHALL requirement because it is a major vulnerability source.	Transitive dependency coverage is a SHOULD. Given that major vulnerabilities consistently originate in transitive dependencies, this should be a SHALL with explicit depth guidance.	3.3	
13	Ibrahim Haddad	VEX is not mentioned	VEX is not mentioned. It is an established complement to SBOM for vulnerability management and is natively supported in CycloneDX 1.4 and later.	Add to Chapter 3	
14	Ibrahim Haddad	Verification is needed after integrating multiple SBOMs.	The guide does not address the topic of SBOM composition and merging. This is a common challenge in multi-tier / complex sw supply chains and a potential practical gap for the intended audience. A merged SBOM should be validated after composition to confirm that no data was lost, no relationships were broken, and no duplicate components were introduced. The guide's quality criteria in section 3 apply to individual SBOM documents but are not explicitly extended to cover the output of a merge operation.	Add to Chapter 3	

https://docs.google.com/spreadsheets/d/13nMWvqYJV8gpZq_7L9rS62kgNRX6G8BucLLu9s8fR_M/edit?gid=0#gid=0

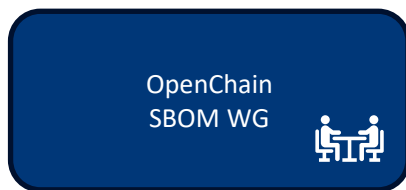
SBOM Working Group – Japan and Global

日本で議論した結果をグローバルコミュニティで精査し、ガイドライン化する



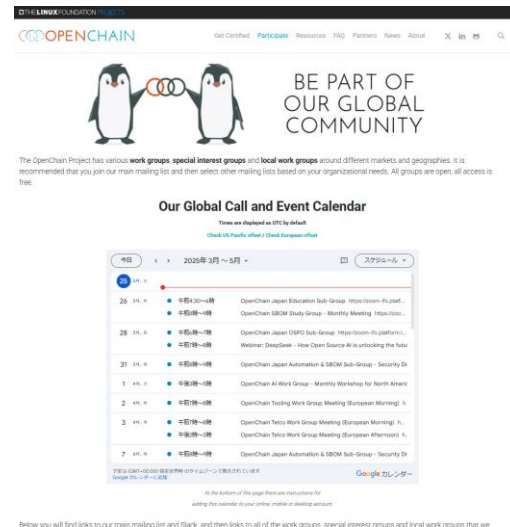
毎週月曜 17:00-18:00 JST

<https://github.com/OpenChain-Project/OpenChain-JWG/tree/master/subgroups/sbom-sg/meetings>



毎月 第4水曜 17:00-18:00 JST

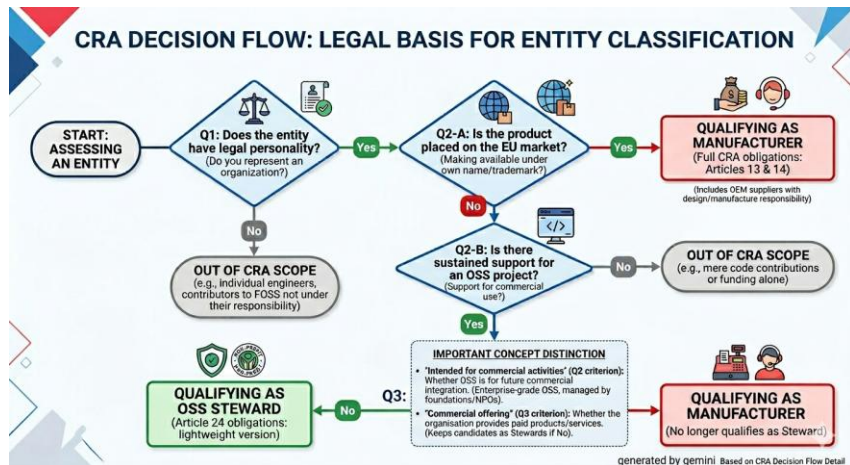
<https://github.com/OpenChain-Project/SBOM-sg>



<https://openchainproject.org/participate>

ここから誰でも参加可能 – zoom call

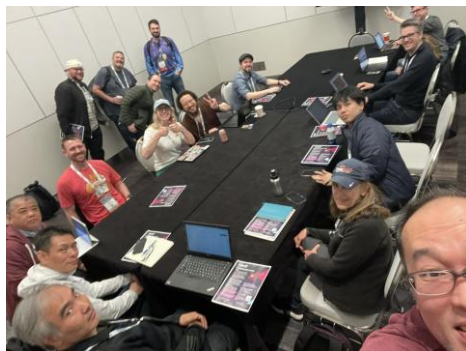
Appendix. Open Source Steward discussion with OpenSSF



Questions / Topics to Discuss with OpenSSF people		
No.	Situation	Our Discussion
1	Corporate-A sells Hardware-A (developed by Corporate-A) to Corporate-B outside Europe. Corporate-A provides OSS-A (developed for Hardware-A) directly to Corporate-B outside Europe. Corporate-B manufactures Product-B incorporating Hardware-A and OSS-A and sells it within Europe.	Corporate-A: Out of scope? Corporate-B: Manufacturer
2	Corporate-A sells Hardware-A (developed by Corporate-A) to Corporate-B outside Europe. Corporate-A publicly releases OSS-A (developed for Hardware-A) on GitHub. Corporate-B manufactures Product-B incorporating Hardware-A and OSS-A and sells it within Europe.	Corporate-A: Steward? Corporate-B: Manufacturer
3	Corporate-A publicly releases OSS-A developed for Hardware-B on GitHub. Corporate-B sells Hardware-B (developed by Corporate-B) to Corporate-C outside Europe. Corporate-B provides OSS-A as sample software directly to Corporate-C. Corporate-C manufactures Product-C incorporating Hardware-B and OSS-A and sells it within Europe.	Corporate-A: Steward? Corporate-B: Out of scope? Corporate-C: Manufacturer
4	Corporate-A publicly released OSS-A developed for Hardware-B on GitHub. However, Corporate-A no longer exists and no one is maintaining it. Corporate-B sells Hardware-B (developed by Corporate-B) to Corporate-C outside Europe. Corporate-B provides OSS-A as sample software directly to Corporate-C. Corporate-C manufactures Product-C incorporating Hardware-B and OSS-A and sells it within Europe.	Corporate-B: Out of scope? Corporate-C: Manufacturer
5	Corporate-A publicly released OSS-A developed by Corporate-A on GitHub but has now withdrawn. Community-A has taken over management of OSS-A from Corporate-A. Corporate-B manufactures Product-B incorporating OSS-A and sells it within Europe.	Corporate-A: Out of scope? Community-A: Steward Corporate-B: Manufacturer
6	Corporate-A operates a public Q&A forum for Product-A (developed by Corporate-A) and explicitly states that code posted without special notice by the poster is treated as OSS. Individual-B posts Snippet-B to that Q&A forum. Corporate-A incorporates the posted Snippet-B into Product-A and sells it within Europe.	Individual-A: Out of scope Corporate-A: Manufacturer
7	An employee of Corporate-A contributes to OSS-A managed by Community-A. (Sign-off: Corporate-A). Corporate-A manufactures Product-B incorporating OSS-A (inclusion that	Corporate-A: Out of scope? Community-A: Steward Corporate-B: Manufacturer

<https://docs.google.com/spreadsheets/d/1Du-b5pcwAVsH-2eavNN5FcVOD-TkN4w5/edit?gid=2067894194#gid=2067894194>

Will be discussed in CRA working group at OpenSSF
<https://openssf.org/groups/global-cyber-policy/>



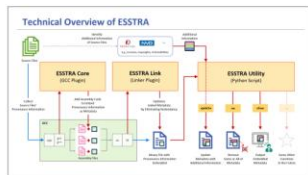
Appendix 2. ESSTRA

What's ESSTRA?



<https://github.com/sony/esstra>

- A tool for visualizing the exact software composition
 - Clearly shows included OSS and third-party components
 - Improves SBOM quality by removing "unexplainable" elements
 - Easy to use—no special expertise required
 - Integrates smoothly into existing development workflows
 - Low-cost, suitable even for binary-only suppliers



8

Challenge: Accurately Tracing the Origin of Installed Binaries Is Difficult

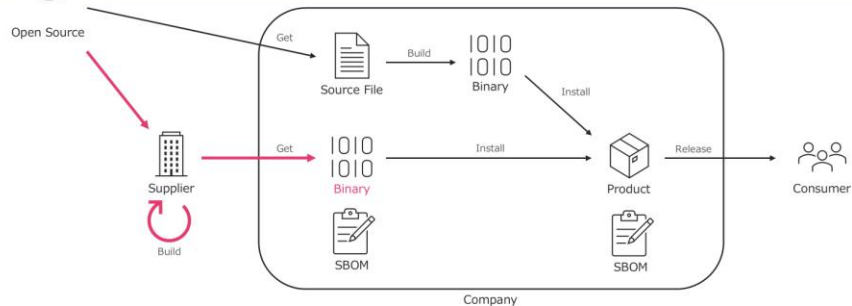


https://github.com/sony/esstra/blob/main/doc/project_overview.md



Open Source

- Sometimes, BSPs are delivered as binaries only, without source code or the ability to perform reproducible builds, making it difficult to verify whether the delivered binaries truly match the provided SBOM



9

Open Compliance Summit 2025

<https://sched.co/28lhB>

